

GMX · SECURITY REVIEW

# GMX

# Timelock Updates.

A security review of Timelock Updates.

| CLIENT | PROJECT          | AUDITORS | AUDIT WINDOW            | FINAL REPORT   |
|--------|------------------|----------|-------------------------|----------------|
| GMX    | Timelock Updates | Guardian | April 3 – April 6, 2026 | April 14, 2026 |

§ 00

# Contents.

14 pages — overview, confidence ranking, scope, 4 findings, disclaimer, and about Guardian.

|      |                          |       |
|------|--------------------------|-------|
| § 01 | Overview                 | P. 03 |
| § 02 | Confidence Ranking       | P. 04 |
| § 03 | Scope & Classifications  | P. 05 |
|      | Files in Scope           | P. 06 |
| § 04 | Findings                 | P. 07 |
|      | Main Review · 4 findings | P. 08 |
| § 05 | Disclaimer               | P. 13 |
| § 06 | About Guardian           | P. 14 |

§ 01

# Overview.

Guardian reviewed Timelock Updates across a single review round. The final report includes 3 Low, 1 Informational findings.

|                         |                                       |
|-------------------------|---------------------------------------|
| AUDIT FIRM              | REPOSITORY                            |
| Guardian                | gmx-io/gmx-contracts                  |
| CLIENT                  | METHODOLOGY                           |
| GMX                     | Smart contract · Manual · Main Review |
| PROJECT                 | MAIN REVIEW COMMIT                    |
| Timelock Updates        | f41c09890b41                          |
| PREPARED BY             |                                       |
| Guardian                |                                       |
| AUDIT WINDOW            |                                       |
| April 3 – April 6, 2026 |                                       |
| FINAL REPORT            |                                       |
| April 14, 2026          |                                       |

## 1.1 Confidence Ranking

5 / 5

Very High Confidence

Guardian assigns a Confidence Ranking of 5 out of 5, combining finding severity, remediation outcome, and the reviewer’s assessment of latent risk. The full scale is on the next page.

|                     |                |                     |                 |                      |
|---------------------|----------------|---------------------|-----------------|----------------------|
| 1                   | 2              | 3                   | 4               | 5                    |
| VERY LOW CONFIDENCE | LOW CONFIDENCE | MODERATE CONFIDENCE | HIGH CONFIDENCE | VERY HIGH CONFIDENCE |

## 1.2 Findings at a Glance

| SEVERITY                  | TOTAL | PENDING | ACK | PARTIAL | RESOLVED |
|---------------------------|-------|---------|-----|---------|----------|
| <div></div> Critical      | 0     | 0       | 0   | 0       | 0        |
| <div></div> High          | 0     | 0       | 0   | 0       | 0        |
| <div></div> Medium        | 0     | 0       | 0   | 0       | 0        |
| <div></div> Low           | 3     | 0       | 3   | 0       | 0        |
| <div></div> Informational | 1     | 0       | 1   | 0       | 0        |
| All severities            | 4     | 0       | 4   | 0       | 0        |

## § 02

# Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

| CONFIDENCE RANKING                               | DEFINITION AND RECOMMENDATION                                                                                                                                                                                               | RISK PROFILE                                                                              |
|--------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------|
| <b>5 Very High Confidence</b><br><b>ASSIGNED</b> | Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit. | 0 High/Critical findings and few Low/Medium severity findings.                            |
| <b>4 High Confidence</b>                         | Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.    | 0-1 High/Critical findings per engagement week and little to no Medium severity findings. |
| <b>3 Moderate Confidence</b>                     | Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.                                                            | Some High/Critical findings, with various Medium severity findings.                       |
| <b>2 Low Confidence</b>                          | Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.                                                                     | Over 6 High and Critical findings across the engagement.                                  |
| <b>1 Very Low Confidence</b>                     | The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.                                                                           | Over 12 High and Critical findings across the engagement.                                 |

## § 03

# Scope & Classifications.

Guardian reviewed Timelock Updates in `gmx-io/gmx-contracts`.

## 3.1 Severity Matrix

|            | IMP · HIGH | IMP · MED | IMP · LOW |
|------------|------------|-----------|-----------|
| LIK · HIGH | Critical   | High      | Medium    |
| LIK · MED  | High       | Medium    | Low       |
| LIK · LOW  | Medium     | Low       | Low       |

### IMPACT · HIGH

Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.

### IMPACT · MEDIUM

Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.

### IMPACT · LOW

Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.

### LIKELIHOOD · HIGH

Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.

### LIKELIHOOD · MEDIUM

Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.

### LIKELIHOOD · LOW

Unlikely to ever occur in production.

# Files in Scope.

| FILE                             | NSLOC | TOTAL |
|----------------------------------|-------|-------|
| No files were recorded in scope. |       |       |

## § 04

# Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in.

| ID          | TITLE                                            | CATEGORY      | SEVERITY      | STATUS       | PAGE  |
|-------------|--------------------------------------------------|---------------|---------------|--------------|-------|
| MAIN REVIEW |                                                  |               |               |              |       |
| L-01        | ReferralTimelock has scope beyond referral admin | Warning       | LOW           | ACKNOWLEDGED | p. 8  |
| L-02        | Referral Timelock config deviates from legacy    | Configuration | LOW           | ACKNOWLEDGED | p. 9  |
| L-03        | Timelocks use outdated Arbitrum config addresses | Configuration | LOW           | ACKNOWLEDGED | p. 10 |
| I-01        | MegaETH Safe uses a different signer set         | Informational | INFORMATIONAL | ACKNOWLEDGED | p. 11 |

LOW **L-01**

ACKNOWLEDGED

# ReferralTimelock has scope beyond referral admin

|          |                             |
|----------|-----------------------------|
| CATEGORY | Warning                     |
| LOCATION | ReferralStorageTimelock.sol |
| REVIEW   | Main Review                 |

## DESCRIPTION

`ReferralStorageTimelock.setHandler` removes the delay for any `IHandlerTarget`, not just `ReferralStorage`. If this timelock is ever made gov/admin of some other handler-gated contract, the multisig can bypass the usual 24 hour handler flow there too. This broadens the scope of the timelock from "referral storage only" change.

## RECOMMENDATION

Consider shrinking the contract to:

- keep only referral-specific methods and variables
- narrow `setHandler` so it can only target the intended `ReferralStorage`
- remove non-referral vault / GLP / token admin functions

## RESOLUTION

Status: Acknowledged.

LOW **L-02**

ACKNOWLEDGED

# Referral Timelock config deviates from legacy

CATEGORY Configuration  
LOCATION ReferralStorageTimelock.sol  
REVIEW Main Review

## DESCRIPTION

The newly deployed Avalanche `ReferralStorageTimelock` at `0x370a34F6200770d79b54080150B61C0326208Ac5` is not configured identically to the currently live Avalanche referral governor.

In particular the old live Avalanche referral governor `0xa252b87040E4b97AFb617962e6b7E90cB508A45F` returns `maxMarginFeeBasisPoints = 500` but the new `ReferralStorageTimelock` returns `maxMarginFeeBasisPoints = 40`.

The deployment script comment is also inconsistent with the configured value, suggesting this may be an unintended config drift:

```
40, // maxMarginFeeBasisPoints 5%
```

While the intended use of this contract appears to be referral administration only, the contract still inherits broader timelock functionality such as fee and leverage-related operations. As a result, this mismatch creates avoidable configuration ambiguity and could produce unexpected behavior if the contract is later used beyond referral actions.

## RECOMMENDATION

Confirm whether the Avalanche value `40` was intentionally chosen.

If the goal is to preserve existing behavior of the live referral governor, update the deployment/configuration to match the current live value `500`.

## RESOLUTION

Status: Acknowledged.

LOW **L-03**

ACKNOWLEDGED

# Timelocks use outdated Arbitrum config addresses

|          |                                           |
|----------|-------------------------------------------|
| CATEGORY | Configuration                             |
| LOCATION | Timelock.sol, ReferralStorageTimelock.sol |
| REVIEW   | Main Review                               |

## DESCRIPTION

The newly deployed Timelocks on Arbitrum are configured with `glpRewardRouter = 0x159854e14A862Df9E39E1D128b8e5F70B4A3cE9B`, while the active reward router is `0x5E4766F932ce00aA4a1A82d3Da85adf15C5694A1` and `feeHandler = 0x7cC506C8d711C2A17B61A75bd082d2514160baAd`, while the active fee handler is `0x7EB417637a3E6d1C19E6d69158c47610b7a5d9B3`.

This should not affect the intended use of the timelocks for payments and referral handling. However, if a related function like `unstakeAndBurnGlp` is ever used, the call may revert or operate against an outdated contract, causing unexpected behavior.

## RECOMMENDATION

Update the timelock configuration to use the active contract addresses, or set the fields to `address(0)`. Consider removing the non-payment/referral flows entirely.

Note: Also check that Position Manager contract `0x75E42e6f01baf1D6022bEa862A28774a9f8a4A0C` points to the current live one.

## RESOLUTION

Status: Acknowledged.

## INFORMATIONAL I-01

ACKNOWLEDGED

# MegaETH Safe uses a different signer set

|          |               |
|----------|---------------|
| CATEGORY | Informational |
| LOCATION | Global        |
| REVIEW   | Main Review   |

## DESCRIPTION

Arbitrum and Avalanche use the same 5-of-8 signer set, while MegaETH also uses a 5-of-8 Safe but replaces one signer with a different address.

The following signer set is used for Arbitrum and Avalanche:

- 0x43A0272D6f74706A8F6F3097FBE9119567f6bBd
- 0x32660E5Fe1C5d10330c019Df4eb522A78c1EC896
- 0x25B889f14B9E5bB65F97b456dcd1ce8a5ab0D855
- 0xd32b86F984254246005a1c1c5e0b6A48743Ddc93
- 0x49C9F377d48c417FEB1f4fb32BF2D9Eb04112Da3
- 0x9fCA624E05EfA27205e905a40f9cEE9cb455D890
- 0xeAA5600595a64a23480b2DF5FCA35A2867c912Ea
- 0xFbf5dC7C8911Bf3434e855374eC81414E44E2b12

MegaETH uses the same threshold, but a different signer set:

- 0x43A0272D6f74706A8F6F3097FBE9119567f6bBd
- 0x32660E5Fe1C5d10330c019Df4eb522A78c1EC896
- 0x25B889f14B9E5bB65F97b456dcd1ce8a5ab0D855
- 0xd32b86F984254246005a1c1c5e0b6A48743Ddc93
- 0x49C9F377d48c417FEB1f4fb32BF2D9Eb04112Da3
- 0x9fCA624E05EfA27205e905a40f9cEE9cb455D890
- 0x89efEB90827965f3C26C8eb959f73696f0f7183d
- 0xFbf5dC7C8911Bf3434e855374eC81414E44E2b12

The signer delta is:

- Removed on MegaETH: 0xeAA5600595a64a23480b2DF5FCA35A2867c912Ea
- Added on MegaETH: 0x89efEB90827965f3C26C8eb959f73696f0f7183d

## RECOMMENDATION

Verify that the divergence is intentional.

---

**I-01** MegaETH Safe uses a different signer set

---

CONTINUED

---

**— RESOLUTION**

Status: Acknowledged.

## § 05

# Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

# About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

**\$45B+**DIGITAL ASSETS UNDER  
REVIEW**200+**

ENGAGEMENTS COMPLETED

**500+**CRITICAL & HIGH FINDINGS  
REPORTED

Reach us at [audits@guardianaudits.com](mailto:audits@guardianaudits.com).